

Cybersecurity

Chiara Sivieri

Winter 2026

Contents

1	Digital scenarios and cyber strategies	4
1.1	Cyberspace and cybersecurity	4
1.2	Recap	5
2	Cyber threats	5
2.1	Introduction to Threat Actors	5
2.2	Taxonomy of Actors	6
2.3	Economics and Influence Operations	7
2.4	Recap	9
3	Information security	9
3.1	Cyber threat vectors and Vulnerabilities	9
3.2	Advanced Vectors and Blind Zones	10
3.3	Recap	11
4	Operational security (cyber threats to industry)	11
4.1	The Nature of Vulnerabilities	11
4.2	Human Vulnerabilities	12
4.3	Technological Vulnerabilities	12
4.4	Governance Failures	13
4.5	Recap	13
5	Software Vulnerabilities	13
5.1	The "Unsaid Truth" of the Software Industry	13
5.2	The OWASP Top 10: Critical Vulnerabilities	14
5.3	Recap	16
6	Cyber Damages	16
6.1	The Conceptual Framework	16
6.2	Detailed Categorization of Damages	16
6.3	Deep Dive into Specific Damages	17
6.4	The Reality vs. Perception (Slide 27)	18
6.5	Geopolitical Conclusions (Slide 28)	18

7	Basic Cyber Defenses	18
7.1	The Methodological Approach: The "Cyber Tailor"	18
7.2	1. Network Defenses (Perimeter Security)	19
7.3	2. Endpoint Defenses	20
7.4	3. Cryptography	21
7.5	4. PKI (Public Key Infrastructure)	21
7.6	5. Backups: The 3-2-1 Rule	22
8	Cybersecurity Strategy: Standards, Governance Compliance	22
8.1	1. The Philosophy: Security vs. Compliance	22
8.2	2. The Governance Vocabulary	22
8.3	3. NIST Cybersecurity Framework (CSF)	23
8.4	4. ISO/IEC 27001 (The Certification)	23
8.5	5. The NIS 2 Directive (EU Law)	23
8.6	6. NIS 2 Technical Requirements (File 9b Detailed)	24
9	Cyber Governance & Management	25
9.1	1. The Hierarchy: Governance vs. Management	25
9.2	2. Documents: Internal vs. External Rules	26
9.3	3. Security Controls (The Core Matrix)	26
9.4	4. The CISO (Chief Information Security Officer)	27
9.5	5. Maturity Models: CMMC	27
10	Advanced Defensive Technologies	27
10.1	1. The Top-Down Methodology	27
10.2	2. Vulnerability Management Cycle	28
10.3	3. Intrusion Detection & Prevention (IDS / IPS)	28
10.4	4. SIEM (Security Information and Event Management)	29
10.5	5. DLP (Data Loss Prevention)	29
10.6	6. Mobile Security (MDM & BYOD)	29
11	Innovative cybersecurity solutions: Zero Trust Architecture (ZTA)	29
11.1	The Collapse of the Castle Metaphor	29
11.2	Definitions and Core Principles (NIST 800-207)	30
11.3	The Logical Architecture of ZTA	31
11.4	The Trust Algorithm and Input Sources	31
11.5	Implementing and Migrating to ZTA	31
11.6	Challenges and "Caveat Emptor"	32
11.7	Recap	32
12	Innovative cybersecurity solutions: Machine Learning for Cybersecurity	32
12.1	Fundamentals of Artificial Intelligence	32
12.2	Evaluation Metrics: Why Accuracy is Dangerous	33
12.3	AI in the Cyber Domain: Offense and Defense	34

12.4	Adversarial Machine Learning	34
12.5	The Challenge of Continual Learning	34
12.6	Recap	35
13	Management of Cyber Risks	35
13.1	The Evolution of Organizational Maturity	35
13.2	The Risk Management Process (ISO/IEC 27005)	35
13.3	Phase 1: Risk Identification and Assets	36
13.4	Phase 2: Risk Analysis (Quantitative vs. Qualitative)	36
13.5	Phase 3: Risk Treatment	37
13.6	Recap	38
14	Cyber Risk Evaluation and Treatment	38
14.1	Risk Evaluation: Making Decisions	38
14.2	Risk Treatment Strategies	38
14.3	Security Controls and Defense in Depth	39
14.4	Focus on Cloud Risks and Misconfiguration	40
14.5	The Engineering Compromise	40
14.6	Recap	41
15	Case Study: Personal Device Usage Policy (ACME S.p.A.)	41
15.1	Purpose, Scope, and Rationale	41
15.2	Operational Guidelines: Do's and Don'ts	42
15.3	Security Requirements and Governance	42
15.4	Recap	42

1 Digital scenarios and cyber strategies

1.1 Cyberspace and cybersecurity

Defining the battlefield

The term **Cybersecurity** is strictly related to the defense of the **Cyberspace**. It is crucial to understand that Cybersecurity is a broader concept than traditional definitions; it is larger than and includes IT security, Logical security, Information security, and Privacy. While it is distinct from Physical security, there are instances where the two merge, sharing similar methodological approaches.

To understand the scope of our defense, we must define the "battlefield": the Cyberspace. An organization lives in the cyberspace and enriches it through culture, economics, finance, business, and media. The entire "cybersecurity game" can be summarized as a conflict between two opposing forces: the **Threats** and the **Organization**.

The evolution of protection targets Over time, the focus of what we need to protect has shifted significantly. Yesterday, the primary goal was to protect **Data**. Today, the perimeter has expanded to include **Data and Services**. Tomorrow, the challenge will be even more complex, as we will need to protect **Data, Services, and Humans**.

This shift is driven by digital evolution. We moved from simple PCs and the early Internet to the World Wide Web, Wi-Fi, and Smartphones. Currently, we are in an era defined by the Internet of Things (IoT), Cloud computing, and Artificial Intelligence. Digitalization transforms everything: business, production, logistics, consumers, relationships, and politics. The entire society has become digital and interconnected. Consequently, the IT department has evolved from a simple unit (1990-2010) to encompassing the entire company (2010-2020), and finally to a complex ecosystem of suppliers and customers (2020 onwards).

Modern user expectations

Modern users demand high-quality and secure services. New generations are not necessarily technological geeks; they know IT services primarily through apps and platforms like Google, Instagram, or Amazon. They accept only services that are intrinsically robust, scalable, and usable, masking their internal complexity. Interestingly, they often do not care much about privacy, finding it acceptable to grant personal data in exchange for "free" services and visibility.

Trends and the Smart World Three major trends are currently shaping the landscape. First, **Human mobility**: we want access to our data and services anytime, anywhere, and on any device. Second, the **Internet of Things (IoT)**: new interconnected devices are being born at a rate of roughly 1000 per minute. Third, the **Smart World**: this is the IoT enriched by intelligence. This applies to the public sector (Smart Cities, enhancing safety and environ-

ment), the private sector (Industry .0, Smart Agriculture), and the mixed sector (Smart Mobility).

The cybersecurity gap and the "Race" The biggest mistake of the recent past was investing only in innovation and digitalization without thinking that any investment must come with cybersecurity. Otherwise, the number of vulnerabilities will increase forever.

This situation creates a "race" between defenders and attackers. Defenders must find and patch hundreds of thousands of existing vulnerabilities before the attackers can find and exploit them. Currently, attackers are often winning this race because they only need to find one vulnerability, whereas defenders must protect against all of them.

Design principles of modern IT services Modern IT services are built on four pillars: **Scalability** (performance guarantee), **Reliability** (response guarantee), **Usability** (transparent complexity), and **Security**.

However, in many contexts, Security is treated as the least important factor compared to Scalability, Reliability, and Usability. It is often the "fourth wheel," implemented only after the others are guaranteed.

1.2 Recap

What is Cybersecurity? It is the defense of the Cyberspace, a domain that includes not just data and computers but the entire digital ecosystem (economy, media, culture). It is broader than simple Information Security.

What are we protecting? The target has evolved from just protecting Data to protecting Data, Services, and now Humans (due to the physical impact of cyber attacks).

The Main Problem: The world prioritized innovation (IoT, Cloud, AI) over security. This created a massive amount of software complexity and vulnerabilities.

The Asymmetry: Cybersecurity is an asymmetric game. Attackers have the advantage because they only need to find one flaw to succeed. Defenders have the disadvantage because they must fix every single flaw to be safe.

Design Conflict: In modern services, companies prioritize Scalability (speed), Reliability (uptime), and Usability (ease of use). Security is often sacrificed or added too late.

2 Cyber threats

2.1 Introduction to Threat Actors

The problem of limited resources In the cybersecurity domain, the attack surface for an organization can be made up of millions of potential targets. It is theoretically impossible to fix all vulnerabilities because no organization has

unlimited resources in terms of time, money, and people (competences). Since resources are finite, defenders must make decisions based on **Priorities**. The core question of cyber strategy is: "How do you decide where to invest your resources?".

The Attribution Problem One of the most complex aspects of analyzing cyber threats is **Attribution** — determining who is responsible for an attack. Attributing a cyberattack to a specific person or group is an extremely daunting task. IP addresses can be spoofed, and attackers often use "stepping stones" (compromised computers in other countries) to hide their location. However, from a Threat Intelligence perspective, trying to identify the actor is essential not necessarily to prosecute them, but to:

1. Classify behaviors.
2. Understand the dynamics and the *modus operandi* (TTPs - Tactics, Techniques, and Procedures).
3. Anticipate the adversary's next move.

2.2 Taxonomy of Actors

The Pyramid of Threat Actors We can classify threat actors based on their motivations and resources. The landscape is often visualized as a pyramid or a diverse ecosystem.

Nation State Actors

At the top of the hierarchy, we find **Nation State Actors**. They are funded by governments and possess virtually unlimited resources (money, time, and talent). Their primary motivations are **Espionage** (political or industrial), **Sabotage**, and **Geopolitical Influence**. They are responsible for the most sophisticated attacks, often referred to as APTs (Advanced Persistent Threats). Unlike common criminals, they are not motivated by quick money but by long-term strategic goals¹.

Cyber Criminals

The most populous group. Their primary motivation is **Money**. Cyber-crime has evolved from isolated hackers to organized "enterprises." They operate with business-like structures, including customer support and R&D. They offer "Cybercrime-as-a-Service," selling malware and tools to less skilled actors. Common attacks include Ransomware, Scams, and Data Theft for resale.

¹See the *CrowdStrike Global Threat Report* provided in the course material for annual trends on Nation State tradecraft, highlighting how adversaries like Russia, China, and North Korea adapt their strategies.

Hacktivists

Their motivation is **Ideology**. They attack targets to promote a political or social cause (e.g., Anonymous). While they may have fewer resources than states, their unpredictability makes them dangerous.

Insiders

Often overlooked, insiders are a major threat because they already have authorized access to the system. They fall into two categories:

- **Disgruntled employees:** Malicious insiders who want to harm the organization for revenge.
- **Incompetent/Negligent employees:** Staff who cause damage accidentally (e.g., clicking a phishing link).

The "Grey" Market: Specialized Companies

A worrying trend is the rise of private companies that develop and sell cyberweapons (spyware, zero-day exploits) legally. These are often called "Predator Companies" or "Cyber Mercenaries." They sell surveillance tools to governments, ostensibly for fighting crime, but these tools are often used by authoritarian regimes to spy on journalists and activists².

2.3 Economics and Influence Operations

The Three Main Markets The digital society has given birth to three massive markets that drive cyber threats:

1. **Data Trade:** The legal (and sometimes illegal) buying and selling of user information.
2. **Cybercrime:** The illegal economy (often operating on the DarkNet³).
3. **E-gaming:** A surprising but lucrative sector for laundering money and fraud.

Data Brokers and the "Free" Service Model The business model of the internet is often summarized as: "If the service is free, you are the product." Users pay for free services (Google, Facebook) with their **Time** and **Data**. This data is collected and resold by **Data Brokers** to advertisers, insurance companies, or even other threat actors. This massive accumulation of personal data creates privacy risks and facilitates targeted attacks⁴.

²Refer to the document "*20/2020 List of Predator Companies*" by Reporters Without Borders (RSF) for a list of companies that sell digital surveillance tools used to violate human rights.

³The *DarkNet Bible* provided in the notes explains the operational security (OpSec) required for actors to operate in these underground markets anonymously.

⁴The *FTC Data Broker Report* highlights the lack of transparency in this industry, where companies collect billions of data points on consumers without their knowledge.

PsyOps and Disinformation Cyber threats are not just about stealing data; they are also about manipulating minds. **PsyOps (Psychological Operations)** use the cyberspace to influence public opinion, beliefs, and behaviors. This includes:

- **Fake News & Disinformation:** Spreading false information to create confusion.
- **Social Control:** Using botnets and trolls to polarize debates.

The goal is **Manipulation:** altering the decision-making process of a target audience (e.g., influencing elections or damaging a company's reputation).

Targeting: Big Prey vs. Non-Big Prey Not all organizations face the same threats. It is crucial to distinguish the threat landscape based on the size and strategic importance of the target:

- **Big Preys (Governments, Critical Infrastructures, Large Corporations):** They are the primary targets of Nation State Actors (APTs) and high-level espionage.
- **Non-Big Preys (SMEs, Universities, Local Public Administration):** They are rarely targeted by Nation States directly. Their main threats come from:
 - **Cyber Criminals:** Looking for easy money (Ransomware, Scams).
 - **Insiders:** Disgruntled or incompetent employees.
 - **Script Kiddies:** Unskilled attackers using automated tools to hit random targets.

The "Non-Big" organizations often make the mistake of thinking "I am too small to be a target." This is false; they are targets of opportunity for criminals and automation.

The Hierarchy of Influence (PsyOps) Psychological Operations are not just about "fake news"; they follow a specific escalation of intensity to orient beliefs and behaviors:

1. **Coercion:** Elimination of alternative choices (forcing the target).
2. **Influence:** Adaptation based on exposure to limited people and confined environments (echo chambers).
3. **Persuasion:** Adaptation based on continuous exposure to emotional information and topics.
4. **Manipulation:** The alteration of cognitive and decision-making processes through the repeated application of the previous steps.

The impact of these operations is not limited to the individual; it escalates from the **Personal** level to the **Community**, the **Company**, the **Society**, and finally the **State**.

2.4 Recap

Why do we need priorities? We cannot defend everything. We must identify the most critical assets because resources (time/money) are limited.

Who attacks us?

- *Nation States*: High budget, espionage/warfare goals.
- *Criminals*: Profit-driven, highly organized ("Crime-as-a-Service").
- *Hacktivists*: Ideology-driven.
- *Insiders*: Dangerous because they are already inside (can be malicious or just careless).

Emerging Threats:

- *Mercenaries (Predator Companies)*: Legitimate businesses selling military-grade spyware.
- *Data Brokers*: The "legal" side of data trading that erodes privacy.
- *PsyOps*: Attacks on human cognition (fake news, manipulation) rather than just software.

3 Information security

3.1 Cyber threat vectors and Vulnerabilities

The Anatomy of the Attack Surface To defend an organization, we must first define the battlefield. The **Attack Surface** represents the sum of all points where an unauthorized user can try to enter data to or extract data from an environment. It is a massive ecosystem composed of software, hardware, networks, and, crucially, users. We must distinguish this from **Threat Vectors**, which are the specific methods or paths adversaries use to breach that surface. While the surface describes *where* we are exposed, the vector describes *how* the attack is delivered.

The Human Factor and Vulnerabilities Threat vectors generally target two main areas: weaknesses in the infrastructure or weaknesses in the employees. A technical weakness is known as a **Vulnerability**. These are cataloged via the CVE (Common Vulnerabilities and Exposures) system and scored using CVSS (Common Vulnerability Scoring System). However, the most critical concept here is the **Window of Exposure**. This is the time elapsed between the discovery of a vulnerability and the application of a patch.

- **Zero-Day**: The vulnerability is known to attackers but not to the vendor. The window is wide open.

- **The Patch Gap:** Even after a patch is released, organizations take time to test and apply it. Attackers exploit this delay. It is a race: defenders must remediate before attackers exploit.

Privilege Escalation: The Hidden Goal Gaining access to a system is often just the first step. As highlighted in the course slides, a critical phase of an intrusion is **Privilege Escalation**. Attackers often enter as a low-level user (e.g., via a phishing email). To do real damage, they need to elevate their rights to "Administrator" or "Root." Detecting privilege escalation is vital because it usually precedes the deployment of malicious payloads or data exfiltration. If defenders can detect this vertical movement, they can stop the attack before the "main event" occurs (Threat Hunting).

The Hierarchy of Attackers Understanding the vector also means understanding the actor behind it. We distinguish three tiers: **Basic Attackers** (Script Kiddies) lack deep skills and use pre-made tools for vandalism or ego. **Opportunistic Attackers** are financially motivated and leverage the "Cybercrime-as-a-Service" market to launch scalable attacks like ransomware against "Non-Big" preys. **Sophisticated Attackers** (APTs/Nation States) develop custom Zero-Day exploits and operate with long-term strategic goals, often remaining undetected for months.

3.2 Advanced Vectors and Blind Zones

Stealth Vectors: Drive-by and Waterholing Modern vectors are designed to be invisible. In a **Drive-by Download** attack, the user does not need to click a link or download a file voluntarily. The infection occurs automatically by simply visiting a legitimate but compromised website. Hidden code (Exploit Kit) on the site scans the user's browser for vulnerabilities and silently installs malware. A more targeted variation is the **Waterhole Attack**. Here, the attacker guesses or observes which websites the target organization frequently visits (e.g., a specific developer forum) and infects that specific site, "poisoning the water" where the prey drinks.

The Problem of "Blind Zones" The traditional perimeter (Firewall/DMZ) is dead. The modern infrastructure is full of **Blind Zones**—areas where the IT department lacks visibility and control. These include **Shadow IT** (unauthorized software installed by employees), **IoT devices** (smart cameras, printers), and **Cloud Services**. Incursions into blind zones are dangerous because they bypass standard monitoring. A prime example mentioned in the course is the Change Healthcare attack. In this case, the attack initiated from a blind zone: a server of a subsidiary company (a supplier) that was not fully monitored by the main organization. This highlights that the most dangerous blind zone is often the **Supply Chain**.

Weaponizing IoT: The Botnet Threat (File c) As detailed in the *Joint Cybersecurity Advisory*, blind zones like SOHO (Small Office/Home Office) routers are actively exploited by Nation State actors (specifically PRC-linked groups like "Integrity Technology Group"). By compromising thousands of these unpatched devices, attackers create massive Botnets. These are not just used for DDoS attacks but serve as a proxy network to hide the attacker's identity while conducting operations against critical targets.

The Evolution of Ransomware (File b) Ransomware is the most prevalent opportunistic threat, but its nature has changed. According to the *State of Ransomware 202* report, the vector has shifted from simple encryption (Denial of Service) to **Data Exfiltration**. Attackers now steal the data before locking it. This is known as Double Extortion: even if the victim restores from backups, the attacker threatens to publish the stolen data. This forces organizations to focus on *preventing the breach* (Data Loss Prevention) rather than just *recovery*.

3.3 Recap

Attack Surface vs. Vector: The surface is the "where" (endpoints, users, cloud); the vector is the "how" (phishing, drive-by, exploit).

Privilege Escalation: Getting in is not enough for an attacker. They need admin rights. Catching them during this "climb" is the best way to stop a breach.

The Blind Zones: You cannot protect what you cannot see. Shadow IT, IoT devices, and especially *Suppliers* (Supply Chain) are the new entry points because they are often unmonitored.

Botnets & IoT: Your home router or office printer might be part of a Chinese state-sponsored botnet used to hide their tracks.

Ransomware 2.0: Backups are no longer the ultimate solution because attackers now *steal* the data before locking it (Double Extortion).

4 Operational security (cyber threats to industry)

4.1 The Nature of Vulnerabilities

The Fundamental Equation To understand cyber risk, we must distinguish between the **Threat** and the **Vulnerability**. The professor uses a classic analogy: *The rain is a threat*. It is an external event that we cannot control; we cannot stop the rain (just as we cannot stop hackers). However, the rain only damages the house if there is a hole in the roof. That hole is the **Vulnerability**. Therefore, the fundamental equation of cybersecurity is:

$$\text{Threat (Rain)} + \text{Vulnerability (Hole)} \rightarrow \text{Damage}$$

Operational security focuses on finding and fixing these "holes" because we have no control over the threats.

Complexity: The Enemy of Security Why are there so many vulnerabilities? The primary culprit is **Complexity**. The cyberspace is composed of billions of lines of code, interconnected networks, and diverse users. As systems become more complex, the probability of errors increases. Vulnerabilities are generally categorized into two macro-families: **Human** and **Technological**.

4.2 Human Vulnerabilities

Culture and Competence The human factor is often the weakest link ("The Layer 8 problem"). This stems from:

- **Lack of Awareness:** Users simply do not know the risks.
- **The Skills Gap:** There is a massive shortage of cybersecurity professionals. While attackers share information and tools globally, defenders often work in silos with limited resources.
- **Cost vs. Investment:** Management often views security as a cost to be minimized rather than an investment, leading to budget cuts for training and personnel.

Shadow IT: The Efficiency Trap A specific human vulnerability highlighted in the course is **Shadow IT**. This occurs when employees use unauthorized software, devices, or cloud services (e.g., using personal WhatsApp for work, unauthorized Dropbox accounts, or personal USB drives) to solve problems faster. Employees do this to increase *productivity* and bypass "bureaucratic" IT restrictions. However, this creates a massive **Blind Zone**. The IT department cannot patch or protect systems they don't know exist.

4.3 Technological Vulnerabilities

Software Flaws Technology is imperfect. Vulnerabilities in software arise from two sources:

1. **Provider Faults:** Insecure coding practices, design flaws, or insufficient testing before release. This is often due to the pressure of "Time-to-Market" (releasing features fast is prioritized over releasing them securely).
2. **User Faults:** Using illegal (pirated) software which cannot be updated, or incompetent installation/configuration.

Legacy Systems and "Forever Days" A critical issue in industry is the persistence of **Legacy Systems**—obsolete hardware or software (e.g., Windows XP). Organizations keep them because replacing them is expensive or they run critical proprietary machinery ("If it works, don't touch it"). However, since vendors no longer release security patches for these systems, any new vulnerability discovered becomes a **"Forever Day"**: a hole that will remain open forever.

4.4 Governance Failures

Management as a Vulnerability Vulnerability is not just about code; it is about **Governance**. Even with good technology, an organization is vulnerable if it lacks proper management processes. Key failures include:

- **Lack of Patch Management:** No defined process for when and how to update systems.
- **Inadequate Authentication/Authorization:** Failing to implement "Need to Know" principles (giving everyone admin rights).
- **Lack of Supplier Control:** Failing to vet the security of third-party vendors (Supply Chain risk).
- **No Incident Management:** Not knowing what to do when a breach occurs.
- **Poor Backups:** Lack of offline, immutable backups to recover from Ransomware.

4.5 Recap

The Goal: We cannot stop the "rain" (Threats), so we must fix the "roof" (Vulnerabilities).

Shadow IT: Born from a desire for efficiency, it creates unmanageable risks because IT cannot see it.

Legacy Systems: They are economic assets but security liabilities. They suffer from "Forever Day" vulnerabilities.

Software Issues: Often caused by prioritizing speed (Time-to-Market) over security (Security-by-Design).

Governance: The lack of policies (Patching, Backups, Supplier Control) is just as dangerous as a software bug.

5 Software Vulnerabilities

5.1 The "Unsaid Truth" of the Software Industry

Prototypes vs. Products The professor highlights a critical anomaly in the software market: it is the only engineering sector where it is acceptable

to sell "prototypes" as finished products. In civil or automotive engineering, a product is tested exhaustively before release. In software, due to the pressure of Time-to-Market, companies release code known to be imperfect, relying on future patches to fix it. This leads to a staggering statistic: 90% of cyber vulnerabilities are due to software errors (bugs). Security is often treated as a "Bolt-on" feature (added at the end) rather than a built-in feature.

Shifting Left: Security by Design To fix this, the industry must move from "Security by Testing" to Security by Design (DevSecOps). This involves "Shifting Left": moving security checks to the earliest phases of the development cycle (Requirements and Coding) rather than waiting for the final Testing phase.

- **Cost of fixing:** Fixing a bug during the design phase costs \$1. Fixing it after release costs \$100+ (plus reputational damage).

5.2 The OWASP Top 10: Critical Vulnerabilities

1. Injection Flaws (SQLi & Command Injection) Injection occurs when untrusted data is sent to an interpreter as part of a command.

- **SQL Injection (SQLi):** The most classic example. Code: `SELECT * FROM users WHERE name = 'user`
Attack: If the user enters `' OR '1'='1`, the query becomes true for *all* rows, dumping the database. *Remediation:* Use Prepared Statements (Parameterized Queries). Never concatenate strings for queries.
- **OS Command Injection:** The attacker injects operating system commands (e.g., adding `; rm -rf /` to a file upload form).

2. Broken Access Control & Path Traversal This category (formerly separate items like IDOR) covers users acting outside their permissions.

- **IDOR (Insecure Direct Object Reference):** Changing the URL ID (`.../user?id=100` to `101`) to see someone else's data.
- **Path Traversal (Directory Traversal):** Highlighted in Slide 84. Attackers use the "dot-dot-slash" sequence (`../`) to climb out of the web root folder and access system files. Example: `http://site.com/view?file=../../../../etc/passwd`
If the application doesn't sanitize the input, it serves the sensitive Linux password file.

3. Cross-Site Scripting (XSS) XSS targets the **user**, not the server. It happens when an application includes untrusted data in a web page without validation.

- **Reflected XSS:** The malicious script is in a link (e.g., a phishing email). When clicked, it executes in the victim's browser.

- **Stored XSS:** The script is saved on the server (e.g., in a forum post). Anyone viewing the post gets infected. *Goal:* Stealing Session Cookies (Session Hijacking). *Remediation:* Input Validation and Output Encoding.

4. Broken Authentication Weaknesses in session management. Examples include: allowing weak passwords, not rotating Session IDs after login, or passing Session IDs in the URL (where they can be seen in browser history). This leads to Session Hijacking: the attacker takes over a valid user's session.

5. Sensitive Data Exposure Failure to encrypt data.

- **In Transit:** Sending passwords over HTTP instead of HTTPS.
- **At Rest:** Storing passwords in plain text or using weak hashing algorithms (MD5) without "Salt".

6. XXE (XML External Entities) Mentioned in Slide 55. Many older applications use XML processors. If configured poorly, these parsers can be tricked into fetching external files (local or remote) when processing an XML upload, leading to data disclosure or Denial of Service (DoS).

7. Insecure Deserialization Mentioned in Slide 65. Serialization converts objects into a stream of bytes to save them; deserialization brings them back. If an application deserializes data from an untrusted source without checking it, an attacker can manipulate the object to execute malicious code.

8. Security Misconfiguration The most common issue.

- Default accounts (`admin/admin`).
- Unpatched servers.
- Verbose error messages (stack traces) that reveal system details to attackers.

9. Using Components with Known Vulnerabilities Modern software relies on third-party libraries (e.g., Log4j). If a library has a CVE and the developer doesn't update it, the application is vulnerable. This is a Supply Chain risk.

10. Insufficient Logging and Monitoring Most breaches take over 200 days to detect. Without logs of failed logins or critical transactions, you cannot detect an attack in real-time, nor can you perform forensics effectively after the fact.

5.3 Recap

The Root Cause: Prioritizing speed (Time-to-Market) over quality leads to insecure software.

Injection vs. XSS: Injection attacks the database/server; XSS attacks the user/browser.

Path Traversal: Using `../` to escape the web folder and read system files (`/etc/passwd`).

Mitigation Strategy: You cannot "test quality in." You must build it in (Security by Design) by sanitizing all inputs and encrypting all sensitive data.

6 Cyber Damages

6.1 The Conceptual Framework

The Iceberg Principle The professor introduces the concept of damages using the Iceberg Analogy.

- **Above the Water (Direct/Visible Costs):** These are the immediate costs you see and pay right away (e.g., the ransom, the IT consultants). They are often the smallest part of the total damage.
- **Below the Water (Indirect/Hidden Costs):** These are the massive, long-term costs that can sink the company. They are harder to quantify immediately but are far more dangerous (e.g., brand destruction, legal battles, loss of market share).

6.2 Detailed Categorization of Damages

The course divides damages into three precise categories based on *who* pays and *when*.

1. First-Party Damage (Short-Term) These are the immediate "Crisis Costs" paid by the victim organization to handle the emergency.

- **Data Recovery:** Expenses to restore data from backups or, in worst-case scenarios, the cost of decrypting them.
- **Service Restoration:** Costs to bring the digital services, websites, and networks back online.
- **Business Interruption (Immediate):** The calculation of income lost during the downtime hours/days.
- **Cyber Extortion:** The actual payment of the ransom (if the company decides to pay).
- **Forensic Investigation:** The cost of hiring high-level experts to answer: *How did they get in? What did they take? Is it over?*

- **Crisis Management:** Fees for PR firms and crisis managers to control the narrative and notify customers legally.

2. First-Party Damage (Long-Term) These are strategic damages that erode the company's value over months or years.

- **Reputational Damage:** The loss of trust. "Trust takes years to build, seconds to break, and forever to repair."
- **Devaluation of Trade Name:** The brand becomes synonymous with "insecure" (e.g., the lasting memory of the Target or Yahoo breaches).
- **Loss of Intellectual Property (IP):** The theft of trade secrets, blueprints, or algorithms. This destroys future competitive advantage.
- **Loss of Competitiveness:** Competitors use the stolen IP to undercut the victim's prices or release similar products faster.
- **Credit Rating Downgrade:** Banks and investors view the company as a higher risk, increasing the cost of borrowing money.
- **Insurance Premium Increase:** After a claim, cyber insurance premiums can skyrocket, or coverage may be denied entirely.

3. Third-Party Damage (Liability) These are costs arising from the organization's legal responsibility toward others.

- **Privacy Liability:** Compensation paid to customers or employees whose personal data (PII) was stolen.
- **Transmission of Malware Liability:** If the victim's compromised system was used to attack a partner (Supply Chain Attack), that partner can sue for damages.
- **Regulatory Fines:** Penalties paid to the government for non-compliance (e.g., GDPR fines for failing to protect data).
- **Media Liability:** Legal costs related to defamation or libel issues arising from the leak of internal communications.

6.3 Deep Dive into Specific Damages

The Cost of Business Interruption This is often the most expensive component. It is not just "Lost Revenue." The formula for Business Interruption is:

$$\text{Cost} = \text{Lost Net Profit} + \text{Continuing Fixed Expenses} + \text{Extra Mitigation Expenses}$$

Crucially, Fixed Expenses (Salaries, Rent, Electricity) must still be paid even if the factory is stopped and generating zero revenue.

Intellectual Property Theft: The Silent Killer The professor distinguishes between two attack styles:

- **Ransomware (Noisy):** You know you are attacked immediately.
- **IP Theft/Espionage (Silent):** The attacker enters, steals the "Secret Formula," and leaves without breaking anything.

The damage here is realized years later when a competitor (often state-sponsored) releases an identical product at half the price, having skipped the R&D costs.

6.4 The Reality vs. Perception (Slide 27)

The "Preparedness Paradox" is a key takeaway:

- **78%** of organizations were hit by ransomware in the past year.
- Only **22%** of those who *thought* they were "well prepared" actually recovered within 24 hours.
- **38%:** The most alarming stat. Only 38% of victims actually fixed the root cause (the vulnerability) that allowed the attack. The rest just patched the symptom, leaving the door open for a repeat attack.

6.5 Geopolitical Conclusions (Slide 28)

The course concludes by shifting the frame from "Money" to "War." Cyber damages are now a tool of Geopolitical Power.

- **Hybrid Warfare:** Cyberattacks are used alongside or instead of kinetic military action to destabilize adversaries.
- **State-Sponsored Actors:** Nations use APTs to target Critical Infrastructure (Power, Water, Finance) not just for profit, but to cause societal panic.
- **Disinformation:** The damage is not just technical. Adversaries use "Fake News" and unverified content to manipulate public opinion and trust.

Final Lesson: Severe cyberattacks are no longer just an insurance issue; they are a **National and Global Security Threat**.

7 Basic Cyber Defenses

7.1 The Methodological Approach: The "Cyber Tailor"

The professor starts with a core concept: You cannot buy security; you must manage it. A "Bad Cyber Tailor" tries to sell a pre-packaged solution (a specific technology or firewall) regardless of the client's needs. A "Good Cyber Tailor" follows this order:

1. Analyze: Understand the organization (Sector, Size, Risk Appetite).
2. Governance: Define policies and processes first.
3. Technology: Select the tools that fit the governance.

7.2 1. Network Defenses (Perimeter Security)

Concept: Targets vs. Goals (Slide 2, Part 2) It is crucial to distinguish between:

- Intermediate Targets: The technical assets attackers hit (Endpoints, Servers, Networks).
- True Goals: What attackers actually want (Data, Money, Disruption/Sabotage).

Defenses must protect the targets to save the goals.

Firewall Generations A Firewall controls traffic between zones of different trust levels.

- Gen 1: Packet Filtering (Stateless): Inspects headers only (IP, Port). Fast, cheap, but low security.
- Gen 2: Stateful Inspection: Tracks the state of connections (e.g., knows if an incoming packet is a response to an internal request).
- Gen 3: Application Proxy (Gateway): Acts as a middleman. It reconstructs the application payload (HTTP, FTP). High security, high resource usage.
- Gen 4: Next-Generation (NGFW): Includes IPS (Intrusion Prevention), User Identity, and Deep Packet Inspection (DPI).

Firewall Architectures (Topology) The slides (36-40) detail how to arrange firewalls. This is critical for network design.

- Bastion Host: A computer fully exposed to attacks (e.g., a Web Server). It must be heavily hardened.
- Dual Homed Host: A computer with two network cards (NICs). One connected to the Internet, one to the LAN. It acts as a bridge. **Risk:* If hacked, the bridge is open.
- Screened Host: The router filters traffic to a single Bastion Host. The internal network is behind the Bastion.
- Screened Subnet (The DMZ): The most secure architecture. Two firewalls create a "buffer zone" (DMZ) between the Internet and the Internal LAN.

The DMZ (Demilitarized Zone) Rules

- Placement: Public-facing servers (Web, Mail, DNS) go in the DMZ.
- Traffic Flow:
 - Internet → DMZ: **Allowed**.
 - DMZ → Internal LAN: **Strictly BLOCKED** (prevents pivoting).
 - Internal LAN → Internet: Allowed.

NAT (Network Address Translation)

- Static NAT: 1 Private IP = 1 Public IP.
- Dynamic NAT (PAT): Many Private IPs = 1 Public IP (distinguished by ports).
- Security Benefit: Hides internal topology from external scanners.

VPN (Virtual Private Network) Slide 63 lists 5 specific types:

1. Remote Access VPN: Client-to-Site (Employee laptop to HQ).
2. SSL VPN: Browser-based, no client software needed (easier for users).
3. Mobile VPN: Designed for unstable connections (switching between 4G and Wi-Fi) without dropping the session.
4. Site-to-Site VPN: Connects two fixed networks (e.g., Branch office to HQ).
5. Cloud VPN: Secure connection to cloud infrastructure (AWS/Azure).

7.3 2. Endpoint Defenses

The endpoint is the new perimeter.

- Hardening: The manual process of securing a device.
 - Remove unnecessary software/services.
 - Change default passwords.
 - Close unused ports.
- Antivirus (Signature-based): Matches files against a database of known malware.
- EDR (Endpoint Detection & Response): Behavioral analysis. Detects anomalies (e.g., "PowerShell is accessing the internet") rather than just bad files.

7.4 3. Cryptography

Kerckhoffs's Principle A fundamental rule in crypto: "The system must remain secure even if everything about the system, except the key, is public knowledge." Security relies on the secrecy of the Key, not the secrecy of the Algorithm.

Encryption Types

- Symmetric (Private Key):
 - 1 Key (K) for both Encrypt and Decrypt.
 - *Pros*: Fast (AES). *Cons*: Key distribution is risky.
- Asymmetric (Public Key):
 - Pair of Keys: Public (K_{pub}) and Private (K_{priv}).
 - $Message + K_{pub} \rightarrow Encrypted$.
 - $Encrypted + K_{priv} \rightarrow Decrypted$.
 - *Pros*: Solves distribution. *Cons*: Slow (RSA).
- Digital Envelope (Hybrid): Use Asymmetric encryption to securely send the Symmetric key, then use Symmetric for the actual data transfer (HTTPS works this way).

Hashing Integrity Hash = Digital Fingerprint.

- Salting: Adding random data to passwords before hashing to stop "Rainbow Table" attacks.

Digital Signature Provides Authenticity and Non-Repudiation. *Mechanism*: Encrypt the Hash of the message with the Sender's Private Key.

7.5 4. PKI (Public Key Infrastructure)

To trust a Public Key, we need a Certificate.

- CA (Certificate Authority): The entity that issues certificates.
- Vulnerabilities: If a CA is compromised, the whole trust chain breaks.
- Famous Breaches (Slide 76):
 - **DigiNotar (2011)**: Dutch CA hacked; attackers issued fake certificates for Google.
 - **Trustwave (2012)**: Issued a Man-in-the-Middle certificate.
 - **Verisign (2010)**: Suffered repeated breaches.

7.6 5. Backups: The 3-2-1 Rule

Ransomware targets backups specifically.

- 3 copies of data.
- 2 different media types.
- 1 copy OFFLINE (Air-gapped). This is the only defense against modern ransomware that encrypts network-attached backups.

8 Cybersecurity Strategy: Standards, Governance Compliance

8.1 1. The Philosophy: Security vs. Compliance

The professor creates a critical distinction between being "Compliant" and being "Secure".

- Paper Compliance: The goal is merely to pass the audit. Policies exist only on paper. This satisfies the auditor but does not stop attackers.
- Risk-Based Security: The goal is to protect the business. Standards are used as a tool to measure maturity, not as a final destination.

The Maturity Model (Slide 2):

1. Reactive: No executive support, underfunded. "Fix it when it breaks."
2. Compliance-Driven: Driven by laws (GDPR, NIS2) or client demands. "Check the box."
3. Mature (Risk-Based): Security is integrated into business processes. Continuous improvement.

8.2 2. The Governance Vocabulary

To establish governance, you must understand the hierarchy of documents:

- Policy (High Level): Mandatory statement of intent. *Example: "All sensitive data must be encrypted."*
- Standard (Mid Level): Mandatory specific rules. *Example: "Use AES-256."*
- Guideline (Low Level): Recommended best practices. Non-mandatory.
- Procedure: Step-by-step instructions.
- Framework: A structure (like a skeleton) to organize all the above (e.g., NIST).

8.3 3. NIST Cybersecurity Framework (CSF)

The NIST CSF is the most popular framework because it is flexible and speaks a common language. **Structure:**

1. Core (The 5 Functions):
 -
 - **Identify:** Asset management, Risk Assessment.
 - **Protect:** Access Control, Training, Maintenance.
 - **Detect:** Anomalies, Continuous Monitoring.
 - **Respond:** Mitigation, Analysis.
 - **Recover:** Recovery Planning, Improvements.
2. Tiers: Measure how well you manage risk (Tier 1: Partial → Tier 4: Adaptive).
3. Profiles: Current Profile (As-Is) vs. Target Profile (To-Be). Used to identify gaps.

8.4 4. ISO/IEC 27001 (The Certification)

Unlike NIST, ISO 27001 is a formal standard you can be Certified against. It focuses on the ISMS (Information Security Management System).

- PDCA Cycle: Based on the "Plan-Do-Check-Act" continuous improvement model.
- Scope: It doesn't just check IT; it checks how management handles security risks.

8.5 5. The NIS 2 Directive (EU Law)

This is the most critical legal topic. It shifts cybersecurity from "Technical" to "Legal/Strategic".

Key Concepts

- Scope: Applies to Medium and Large enterprises in critical sectors.
- "All-Hazards" Approach: Defenses must cover NOT just cyberattacks, but also physical disasters, power outages, and human error.
- Management Liability: Top management (Board/CEO) is personally liable for non-compliance. They must undergo mandatory training and cannot delegate the *responsibility* (even if they delegate the task).

Entity Classification

- Essential Entities (EE): Energy, Transport, Banking, Health, Water, Digital Infra (Cloud/DNS).
- *Supervision*: Ex-Ante (Audited proactively before anything happens).
- Important Entities (IE): Postal, Waste, Food, Manufacturing, Chemicals.
- *Supervision*: Ex-Post (Audited only after an incident occurs).

Incident Reporting (Strict Deadlines)

- 24 Hours: Early Warning (Significant incident suspected).
- 72 Hours: Incident Notification (Assessment of severity).
- 1 Month: Final Report (Root cause analysis).

8.6 6. NIS 2 Technical Requirements (File 9b Detailed)

Based on the Implementing Regulation, these are the mandatory technical measures:

A. Governance Risk

- Policy: Must be written, approved by management, and version-controlled.
- Risk Management: Must be continuous, not a one-time activity.

B. Supply Chain Security (Critical)

- You are responsible for the security of your suppliers (MSPs, Software vendors).
- You must verify if your suppliers have valid security policies. *If your supplier gets hacked and infects you, it is YOUR fault under NIS2.*

C. Human Resources (HR)

- Background Checks: Required for sensitive roles.
- Onboarding/Offboarding: Access rights must be revoked *immediately* upon termination.
- Training: Regular phishing and social engineering awareness.

D. Access Control (Identity)

- MFA (Multi-Factor Authentication): MANDATORY for remote access, privileged accounts, and access to critical assets.
- Password Policy: Enforce complexity and rotation.

E. Physical & Environmental Security

- Perimeter: Define secure areas (badges, biometrics).
- Monitoring: Logs of physical access and CCTV.
- Clear Desk Policy: Confidential documents must not be left visible.

F. Operations Crypto

- Asset Management: Keep an up-to-date inventory of Hardware/Software.
- Cryptography: Policy on encryption and Key Management (lifecycle of keys).
- Backups: Must be separated from the production network (Offline/Immutable).

9 Cyber Governance & Management

9.1 1. The Hierarchy: Governance vs. Management

There is a strict top-down hierarchy. You cannot start with technology.

- Governance (Strategic - "The What"):
 - **Who:** Board of Directors, CEO.
 - **Goal:** Strategic alignment, Risk appetite, Value delivery.
 - *Motto:* "Doing the right things."
- Management (Tactical - "The How"):
 - **Who:** C-Level (CIO, CISO), Managers.
 - **Goal:** Planning, Building, Running, Monitoring.
 - *Motto:* "Doing things right."
- Technology (Operational - "The Tool"):
 - **Who:** IT Staff, Security Analysts.
 - *Reality Check:* Technology is just an enabler of the strategy.

The Top-Down Flow (Slide 4):

Context (Laws/Market) → Business Goals → IT Strategy → Security Strategy

9.2 2. Documents: Internal vs. External Rules

- Internal (For Employees):
 - Policy: Mandatory, high-level intent (e.g., "Encrypt all data").
 - Procedure: Mandatory, step-by-step instructions.
- External (For Customers):
 - Terms of Service (ToS) / Terms of Use: Legal agreements defining what a user can/cannot do on your platform (e.g., Facebook, Apple).
 - *Note*: Legally, "Terms of Service" and "Terms of Use" are effectively the same.

9.3 3. Security Controls (The Core Matrix)

A "Control" is a countermeasure to modify risk. They are classified by Type (Nature) and Function (Timing/Action).

A. Classification by Implementation Type

1. Physical: Tangible measures.
 - **Examples:** Fences, Locks, Guards, CCTV, Fire suppression.
2. Technical (Logical): Hardware/Software.
 - **Examples:** Firewalls, Encryption, Antivirus, IDS/IPS, Biometrics.
3. Administrative (Managerial): Rules and People.
 - **Examples:** Policies, Background checks, Training, Separation of Duties (SoD).

B. Classification by Function (Crucial for Exam)

1. Preventive: Stop the attack **before** it succeeds. (e.g., Firewall, Encryption, Locked door).
2. Detective: Identify the attack **during** or **after**. (e.g., Logs, CCTV recording, IDS).
3. Corrective: Restore systems **after** an incident. (e.g., Backups, Patching).
4. Deterrent: Discourage the attacker psychologically. (e.g., "Warning: Video Surveillance" sign, visible guards).
5. Compensating: An alternative control used when the primary control is too expensive or impossible to implement. (e.g., If you can't encrypt a legacy database, you isolate it in a separate VLAN).

9.4 4. The CISO (Chief Information Security Officer)

The Reporting Line Problem:

- Ideal: CISO reports to CEO/Board (Focus on Risk Management).
- Common (Bad): CISO reports to CIO (IT Director).
- The Conflict of Interest: The CIO prioritizes *Performance/Speed* (make it work). The CISO prioritizes *Security/Control* (make it safe). If the CISO reports to the CIO, security is often overruled to release software faster.

9.5 5. Maturity Models: CMMC

The CMMC (Cybersecurity Maturity Model Certification) is used (e.g., by US Defense) to verify that a company doesn't just "have" security, but "lives" it.

- Level 1 (Foundational): Ad-hoc practices. You do it, but maybe not consistently.
- Level 2 (Advanced): Documented processes. Everything is written down and repeatable.
- Key Domain Example - Access Control (AC):
 - *Goal*: Limit access to authorized users.
 - *Control*: Verify connections and limit external systems.
- Key Domain Example - Identification Authentication (IA):
 - *Goal*: Verify identity (who you are) before granting access (rights).

10 Advanced Defensive Technologies

Reference: File 11. Modern technologies.pdf

10.1 1. The Top-Down Methodology

Technology is not the starting point; it is the implementation of a strategy.

Business Goals → Risk Analysis → Policies (What) → Procedures (How) → TECHNOLOGIES

- **The CISO Role:** The CISO is an executive manager, not just a technician. They define the vision and select technologies to enforce the policies approved by the Board.

10.2 2. Vulnerability Management Cycle

Patching is not a one-time event ("Windows Update"), but a formal cyclical process:

1. **Discovery:** Scan the network to inventory assets and identify weaknesses.
2. **Prioritization:** Use scoring systems like **CVSS** (Common Vulnerability Scoring System) to rank risks (e.g., CVSS 9.8 is Critical).
3. **Remediation:**
 - *Patching:* Applying the official fix.
 - *Workaround:* Applying a temporary configuration change if no patch exists.
4. **Verification:** Rescanning to confirm the vulnerability is closed.

10.3 3. Intrusion Detection & Prevention (IDS / IPS)

These systems inspect traffic content, unlike standard firewalls which only check headers (IP/Port).

Classification by Action

- **IDS (Intrusion Detection System):** Passive. It listens to a copy of the traffic (Promiscuous mode). If it sees an attack, it sends an **Alert**. It *cannot* stop the attack.
- **IPS (Intrusion Prevention System):** Active. It sits in-line with traffic. If it sees an attack, it can **Drop** the packet immediately.

Classification by Detection Method

- **Signature-Based:** Matches traffic against a database of known attacks.
 - *Pro:* High precision.
 - *Con:* Cannot detect Zero-Day attacks.
- **Anomaly-Based:** Builds a baseline of "normal" traffic. Alerts on deviations.
 - *Pro:* Can detect new attacks.
 - *Con:* High rate of **False Positives**.

Critical Exam Concept: A False Positive in an IDS is an annoyance (log spam). A False Positive in an IPS is a **business disruption** (it blocks legitimate traffic).

10.4 4. SIEM (Security Information and Event Management)

The "Brain" of the SOC (Security Operations Center). It solves log fatigue.

- **Aggregation:** Collects logs from all sources (Firewall, Server, AD).
- **Normalization:** Standardizes log formats.
- **Correlation:** Connects disparate events to identify a pattern.
 - *Example:* "Failed Login on Server A" + "VPN Connection from Unusual Location" = **Compromised Account Alert**.

10.5 5. DLP (Data Loss Prevention)

Prevents sensitive data (IP, PII) from leaving the organization. Protects data in three states:

1. **Data at Rest (Storage):** Scans hard drives/NAS. Encrypts or moves unprotected sensitive files. (*e.g., RSA DLP Datacenter*).
2. **Data in Motion (Network):** Inspects outbound traffic (Email/Web). Blocks transmission of sensitive files. (*e.g., Cisco IronPort*).
3. **Data in Use (Endpoint):** Agent on the PC. Blocks copy-paste, screenshots, or USB transfers of sensitive data. (*e.g., RSA DLP Endpoint*).

10.6 6. Mobile Security (MDM & BYOD)

When using personal devices (BYOD), the perimeter disappears.

- **MDM (Mobile Device Management):** Centralized control (Remote Wipe, Enforced PIN).
- **Containerization:** Creates an encrypted "sandbox" on the phone.
 - Corporate apps (Outlook) live inside the container.
 - Personal apps (WhatsApp) live outside.
 - **Isolation:** Data cannot be copied from the container to the personal area.

11 Innovative cybersecurity solutions: Zero Trust Architecture (ZTA)

11.1 The Collapse of the Castle Metaphor

The End of the Perimeter

The professor begins by deconstructing the traditional model of cybersecurity, known as the "Castle and Moat" approach. Historically, we believed that

we could protect our assets by building a strong perimeter (Firewall/DMZ) and trusting everything inside it. However, this model is now obsolete. The perimeter has dissolved due to Cloud services, Mobile devices, and Remote Working (WFH). The attacker is often already inside, or moves sideways (lateral movement) without obstacles once the perimeter is breached. Furthermore, the professor states a harsh truth: **"If our security depends on people, you have lost."** Users are susceptible to phishing, use weak passwords, and introduce Shadow IT (unauthorized cloud apps) into the environment. Therefore, we must remove implicit trust from the user.

The Paradigm Shift

We face a disruptive change. The new assumption is that the network is **always hostile**. We cannot trust a connection just because it originates from the "internal LAN" or a specific IP address. This leads to the core philosophy of Zero Trust, coined by John Kindervag (Forrester) in 2010: **"Never Trust, Always Verify."** In this model, trust is never granted implicitly but must be continuously evaluated.

11.2 Definitions and Core Principles (NIST 800-207)

Zero Trust (ZT) vs. Zero Trust Architecture (ZTA)

It is important to distinguish the concept from the implementation. **Zero Trust (ZT)** is the cybersecurity paradigm (the philosophy) that focuses on protecting resources rather than network segments. It assumes there is no implicit trust based on physical or network location. **Zero Trust Architecture (ZTA)** is the enterprise cybersecurity plan that utilizes ZT concepts. It encompasses the relationships between components, workflow planning, and access policies.

The Tenets of Zero Trust

According to the NIST 800-207 standard, a ZTA is defined by several non-negotiable tenets. First, **all data sources and computing services are considered resources**. A user's laptop is a resource; a SaaS application is a resource. Second, **all communication is secured regardless of network location**. Being in the office HQ does not grant you more trust than being in a coffee shop. Access requests must meet the same security requirements (encryption, authentication). Third, **access to individual enterprise resources is granted on a per-session basis**. You do not authenticate "once" for the whole day. Every request is evaluated. Fourth, access is determined by **dynamic policy**. This includes the state of the client identity, the application, and the observable state of the requesting asset (e.g., is the antivirus updated? Is the location usual?). Finally, the enterprise must collect as much information as possible about the current state of assets and continuously monitor the integrity of the infrastructure.

11.3 The Logical Architecture of ZTA

The Separation of Planes

The most critical technical aspect of ZTA is the separation between the **Data Plane** (where the actual traffic flows) and the **Control Plane** (where the decision is made). The user talks to the resource on the Data Plane, but the "gate" is controlled by a decision made on the Control Plane.

The Core Components: PDP and PEP

The architecture revolves around two main logical components: the "Brain" and the "Muscle".

1. The Policy Decision Point (PDP) - The Brain The PDP is responsible for deciding whether to grant access. It breaks down into two sub-engines:

- **Policy Engine (PE):** This is the ultimate decision-maker. It uses the "Trust Algorithm" to grant, deny, or revoke access based on enterprise policy and input from external sources (CDM systems, Threat Intel).
- **Policy Administrator (PA):** This component executes the PE's decision. If the PE says "Yes," the PA generates a session token or credentials and commands the enforcement point to open the gate.

2. The Policy Enforcement Point (PEP) - The Muscle The PEP is the gatekeeper. It is placed physically or logically in front of the resource. It intercepts the user's request and forwards it to the PDP. The PEP has no brain; it only obeys the PDP. If the PDP says "Allow," the PEP lets the traffic pass to the enterprise resource. If the PDP says "Block," the connection is dropped.

11.4 The Trust Algorithm and Input Sources

How the Decision is Made

The Policy Engine (PE) does not decide based on a static password. It uses a complex **Trust Algorithm**. The decision is a function of multiple inputs: **The Subject:** Who is requesting access? (User ID, Role). **The Asset:** What is the health status of the device? (Is the OS patched? Is it a corporate device or BYOD?). **The Environment:** Contextual data (Time of day, Geolocation). **Threat Intelligence:** Is this IP known to be malicious? Are there active attacks on the internet? **Data Sensitivity:** What is the classification of the resource being accessed?

The PE weighs these factors and produces a "Confidence Score". If the score is higher than the resource's required threshold, access is granted.

11.5 Implementing and Migrating to ZTA

Deployment Models

There is no single way to deploy ZTA. Common approaches include: **Device Agent/Gateway:** An agent on the laptop intercepts traffic and talks to

the PDP. **Enclave-based:** The PEP protects a whole segment of the network (Gateway). **Resource Portal:** The user logs into a web portal (PEP) to see applications. **Sandbox:** The application runs in an isolated container.

The Migration Journey

You cannot switch to Zero Trust overnight. The professor outlines a gradual migration process: 1. **Identify Actors:** Who are your users? 2. **Identify Assets:** What do you need to protect? 3. **Identify Processes:** How does traffic flow? 4. **Formulate Policies:** Who can talk to whom? 5. **Initial Deployment:** Start in "Monitoring Mode" (Audit only) without blocking, to learn the baseline. 6. **Expand:** Gradually enforce blocking rules.

11.6 Challenges and "Caveat Emptor"

The Vendor Trap

The professor issues a warning ("Caveat Emptor" - Buyer Beware). Many vendors claim to sell "Zero Trust in a Box." This is misleading. ****Zero Trust is not a product; it is a strategy.**** Implementing ZTA requires a cultural shift, significant budget, and a multi-year effort. It requires governance, not just technology. No single firewall or software can make you "Zero Trust compliant" if you don't change how you manage identities and policies.

11.7 Recap

Perimeter is Dead: The "Castle and Moat" model fails because users are phishing-prone and the perimeter has dissolved (Cloud/Mobile).

Never Trust, Always Verify: The core philosophy. Access is never implicit based on IP address. It is dynamic and per-session.

PDP (Brain) vs. PEP (Muscle): The Policy Decision Point (PDP) decides access based on a Trust Algorithm. The Policy Enforcement Point (PEP) sits in front of the resource and enforces that decision.

Control vs. Data Plane: Decisions happen out-of-band (Control Plane); traffic flows in-band (Data Plane).

Context is King: The decision depends on User + Device Health + Location + Threat Intel.

Not a Product: You cannot buy Zero Trust. It is a long-term architectural and cultural transition.

12 Innovative cybersecurity solutions: Machine Learning for Cybersecurity

12.1 Fundamentals of Artificial Intelligence

Defining the Hierarchy

It is crucial to first clarify the terminology, as these terms are often used

interchangeably but represent different layers of depth. **Artificial Intelligence (AI)** is the broad discipline that enables machines to mimic human behavior. Inside AI, we have **Machine Learning (ML)**, which refers to systems that learn from data using statistical methods to make predictions without being explicitly programmed for every single rule. Finally, **Deep Learning (DL)** is a subset of ML that uses multi-layered neural networks to process complex data (like images or raw traffic) to find hidden patterns.

The Learning Paradigms

Machine Learning models learn in three primary ways. **Supervised Learning** is like learning with a teacher: the data is "labeled." We tell the system, "This file is malware" and "This file is benign." The model learns the relationship between the features and the label. This is used for classification (e.g., Spam vs. Ham). **Unsupervised Learning** is learning without a teacher: the data has no labels. The model must find structure on its own. It is used for *Clustering* (grouping similar entities), which is vital for finding anomalies in network traffic without knowing what an attack looks like beforehand. **Reinforcement Learning** is learning by trial and error. An agent performs actions in an environment and receives a "reward" or a "penalty."

The Problem of Overfitting and Underfitting

When training a model, we aim for generalization. **Underfitting** happens when the model is too simple (like a student who didn't study enough) and cannot capture the pattern of the data. **Overfitting** is the opposite and more dangerous error: the model learns the training data *too well*, memorizing the noise and specific details (like a student who memorizes the textbook pages but doesn't understand the subject). An overfitted model works perfectly on test data but fails miserably on real-world data.

12.2 Evaluation Metrics: Why Accuracy is Dangerous

The Confusion Matrix

To evaluate a model, we compare its predictions against reality. This produces four outcomes: **True Positive (TP)**: Attack correctly identified as an attack. **True Negative (TN)**: Benign traffic correctly identified as benign. **False Positive (FP)**: Benign traffic incorrectly flagged as an attack (False Alarm). **False Negative (FN)**: Attack incorrectly labeled as safe. This is the most dangerous outcome in cybersecurity.

The Accuracy Paradox

In cybersecurity, data is highly **imbalanced**. 99.9% of traffic is benign, and only 0.1% is malicious. If you create a "dummy" model that says "Everything is Safe," it will have 99.9% Accuracy. However, it is useless because it misses every single attack. Therefore, **Accuracy is a misleading metric in security**. We must instead look at: **Precision**: When the model says "Attack," how often

is it right? (Crucial to avoid alert fatigue). **Recall:** Out of all real attacks, how many did we catch? (Crucial for safety). **F1-Score:** The harmonic mean between Precision and Recall.

12.3 AI in the Cyber Domain: Offense and Defense

AI for the Attacker (Offensive AI)

Threat actors use AI to automate and enhance their attacks. We see **Deep-Fakes** for social engineering, automated phishing campaigns that tailor emails to the victim, and malware that uses AI to adapt its behavior to avoid detection.

AI for the Defender (Defensive AI)

On the defensive side, AI is the evolution of the Intrusion Detection System (IDS). Traditional IDS uses **Signatures** (looking for known patterns). This is precise but blind to "Zero-Day" attacks. AI-based IDS uses **Anomaly Detection**. It learns what "normal" traffic looks like. If a user who usually downloads 10MB suddenly downloads 10GB, the AI flags it, even if the specific attack method is unknown. A key application is **UEBA (User and Entity Behavior Analytics)**, which monitors user habits to detect compromised accounts (e.g., login at 3 AM from a foreign country).

12.4 Adversarial Machine Learning

Attacking the Brain

Since we rely on AI for defense, hackers now attack the AI models themselves. This is known as Adversarial ML. **Poisoning Attacks** occur during the training phase. The attacker injects malicious data labeled as "safe" into the training set. This creates a "backdoor" in the model (e.g., "if the file has this specific byte sequence, ignore it"). **Evasion Attacks** occur during the inference phase (when the model is running). The attacker slightly modifies the malware (adding noise or junk code) so that the AI classifies it as benign, even though it is still malicious.

12.5 The Challenge of Continual Learning

Catastrophic Forgetting

The digital world changes fast (Concept Drift). New attacks appear every day. Static models become obsolete quickly. However, if we simply retrain the model on new data, it suffers from **Catastrophic Forgetting**: it learns the new attacks but completely forgets how to detect the old ones. The neural network overwrites its previous weights.

Solving the Stability-Plasticity Dilemma

We need models that are "Plastic" enough to learn new things, but "Stable" enough to remember old ones. The most effective approach currently is **Replay**: we store a small buffer of old data and mix it with the new data during training.

Another frontier is **Few-Shot Learning**: teaching an AI to recognize a new attack type seeing only 1 or 5 examples (instead of thousands), similar to how humans learn.

12.6 Recap

AI vs ML vs DL: AI is the concept; ML is the statistical method; DL is the neural network approach.

Don't trust Accuracy: In security, attacks are rare events. High accuracy often hides a model that misses all attacks (False Negatives). Focus on Recall (catching the bad guys) and Precision (reducing false alarms).

Anomaly over Signature: AI allows us to move from "matching known patterns" (useless against Zero-Days) to "detecting strange behaviors" (Anomaly Detection).

Adversarial AI: Hackers attack the model itself. *Poisoning* corrupts the training data (injecting a backdoor); *Evasion* fools the live system.

Catastrophic Forgetting: The tendency of AI to forget old knowledge when learning new tasks. Solving this (via Continual Learning) is the key to sustainable cyber defense.

13 Management of Cyber Risks

13.1 The Evolution of Organizational Maturity

The professor outlines three distinct approaches that organizations typically take regarding cybersecurity, creating a maturity scale. The first level is the **Reactive Organization**. These entities lack executive support, are often underfunded and understaffed, and operate without metrics. Their strategy is essentially "wait for a disaster and try to fix it." They are set up for cyber failure. The second level is the **Compliance-Driven Organization**. Here, security is based on controls and checklists to satisfy external standards (like GDPR, ISO 27001, or PCI-DSS). While better than the reactive approach, the goal is often just to "pass the audit" rather than to be truly secure. The highest level is the **Risk-Based (Mature) Organization**. In this model, cybersecurity is integrated into business processes. Decisions are based on data and analytics, and new technologies are evaluated proactively. The organization understands that security is not a checklist but a continuous management of risks affecting business goals.

13.2 The Risk Management Process (ISO/IEC 27005)

The Definition of Risk

Risk is not a vague concept but a specific function. It is defined as the possibility that a specific threat exploits a vulnerability causing damage to an

asset. The fundamental formula is:

$$\text{Risk} = f(\text{Threat, Vulnerability, Damage})$$

Therefore, Risk Management is the structured process of identifying, assessing, and reducing this risk to an acceptable level.

The Cycle Steps

The process follows a logical flow, often referred to as the Risk Assessment cycle: 1. **Context Establishment:** Defining the scope and boundaries. 2. **Risk Identification:** Finding the assets and the threats. 3. **Risk Analysis:** Estimating the probability and impact (Qualitative or Quantitative). 4. **Risk Evaluation:** Comparing the result against the risk appetite. 5. **Risk Treatment:** Deciding what to do with the risk.

13.3 Phase 1: Risk Identification and Assets

Identifying Critical Services (The 3+1 Rule)

You cannot protect everything equally. The professor suggests identifying the "3+1" most critical services to prioritize efforts: 1. **Financial Impact Services:** Products that generate revenue *now* (Pillar products). 2. **Strategic Services:** Products that will generate revenue in the *future* (Growing products). 3. **Foundational Services:** Enabling platforms (like the ERP or the Cloud infrastructure) without which the company stops. The "+1" is **Reputation**, which is an intangible but critical asset that spans across all others.

Vulnerability Assessment (VA) vs. Penetration Testing (PT)

To identify technical vulnerabilities, organizations use two distinct methods. **Vulnerability Assessment (VA)** is an automated scan (using tools like Nessus or OpenVAS) that lists all known open doors. It is broad but can generate false positives. **Penetration Testing (PT)** is a manual, authorized simulation of an attack. A human expert tries to exploit the vulnerabilities found by the VA to prove the risk is real. PT is deeper but more expensive and limited in scope.

13.4 Phase 2: Risk Analysis (Quantitative vs. Qualitative)

Quantitative Analysis (The Math of Risk)

This method attempts to assign financial values to risk. It uses specific formulas to calculate the **ALE (Annualized Loss Expectancy)**. First, we calculate the **SLE (Single Loss Expectancy)**, which is the cost of a single incident ($\text{Asset Value} \times \text{Exposure Factor}$). Second, we determine the **ARO (Annualized Rate of Occurrence)**, which is how many times per year we expect the incident to happen. The final formula is:

$$\text{ALE} = \text{SLE} \times \text{ARO}$$

This allows calculating the **ROI (Return on Investment)** of a security control. If the cost of the countermeasure is less than the reduction in ALE, the investment is justified:

$$\text{ROI} = \frac{(\text{ALE}_{\text{prior}} - \text{ALE}_{\text{post}}) - \text{Cost}_{\text{control}}}{\text{Cost}_{\text{control}}}$$

While mathematically precise, this method often suffers from the "Garbage In, Garbage Out" problem because exact data on probability is hard to obtain.

Qualitative Analysis (The Heatmap)

Due to the difficulty of getting exact numbers, most organizations use Qualitative Analysis. This involves mapping risks on a matrix based on descriptive scales (e.g., Low, Medium, High, Extreme) for both **Likelihood** and **Impact**. The intersection of Likelihood and Impact creates a "Heatmap" or Risk Matrix, which visually highlights the most critical risks (usually in the red top-right corner) that require immediate attention.

13.5 Phase 3: Risk Treatment

Once the risk is analyzed, management must decide how to handle it. There are only four possible strategies:

1. Avoid (Terminate)

The organization decides that the risk is too high and cannot be mitigated. Therefore, the activity causing the risk is stopped entirely (e.g., deciding not to launch a product in a high-risk country).

2. Mitigate (Modify/Treat)

This is the most common approach. The organization implements controls (firewalls, encryption, training) to reduce the Likelihood and/or the Impact of the threat. This introduces the concept of **Residual Risk**:

$$\text{Residual Risk} = \text{Inherent Risk} - \text{Mitigation Capabilities}$$

The goal is to bring the Residual Risk below the acceptable threshold (Risk Appetite).

3. Transfer (Share)

The organization shifts the financial impact of the risk to a third party, typically through **Cyber Insurance**. It is important to note that you can transfer the financial cost, but you **cannot transfer the reputation loss** or the legal accountability (e.g., GDPR fines remain your responsibility). Cyber insurance covers "First-party liabilities" (your own costs, like data recovery) and "Third-party liabilities" (damages you cause to others). However, exclusions like "Act of War" are becoming major issues in modern policies.

4. Accept (Retain)

The organization acknowledges the risk but decides to do nothing. This occurs when the cost of mitigation is higher than the potential damage, or the risk falls within the acceptable "Risk Appetite." This decision must be formally signed off by management.

13.6 Recap

The Goal: Move from a Reactive or Compliance-driven mindset to a Risk-based mindset.

The Equation: $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$. You manage risk by reducing Vulnerability (patching) or Impact (backups/insurance).

Quantitative vs. Qualitative: Quantitative tries to predict money lost per year ($\text{ALE} = \text{SLE} \times \text{ARO}$), but is hard to calculate accurately. Qualitative uses the Risk Matrix (Likelihood vs. Impact) and is more common for communicating with the Board.

The 4 Treatments: 1. **Avoid:** Stop the activity. 2. **Mitigate:** Apply security controls. 3. **Transfer:** Buy insurance. 4. **Accept:** Live with the risk.

Residual Risk: The risk that remains after you have applied your defenses. This is what the CISO must monitor constantly.

14 Cyber Risk Evaluation and Treatment

14.1 Risk Evaluation: Making Decisions

From Analysis to Evaluation

Following the ISO/IEC 27005 framework, after identifying and analyzing the risks (determining probability and impact), the organization moves to the **Risk Evaluation** phase. While analysis provides the data (e.g., "This event has a High probability and High impact"), evaluation provides the business context. The goal is to compare the results of the risk analysis against the organization's **Risk Appetite** and **Risk Criteria**. We must determine which risks are acceptable and which are not. This process leads to prioritization: deciding which risks require immediate treatment and which can wait.

The Role of the CISO

In this phase, the CISO plays a critical bridge role. They must translate technical findings into business language for the Board. The CISO does not just present a list of vulnerabilities; they present a **Risk Treatment Strategy**. This involves justifying the investment in countermeasures by demonstrating how they reduce the risk to an acceptable level.

14.2 Risk Treatment Strategies

The Four Options

Once a risk is evaluated as unacceptable, management must select a treat-

ment option. The professor reiterates the four canonical strategies: 1. **Risk Modification (Mitigation)**: This is the most common approach. It involves implementing security controls (technology, policies, or procedures) to reduce the likelihood of the threat or the impact of the damage. 2. **Risk Retention (Acceptance)**: The organization consciously decides to live with the risk. This occurs when the cost of mitigation exceeds the potential loss, or the risk is already below the acceptance threshold. This must be a formal decision, not an oversight. 3. **Risk Avoidance (Termination)**: The organization stops the specific activity or business process that generates the risk. For example, shutting down an old server that cannot be patched or withdrawing a product from a high-risk market. 4. **Risk Sharing (Transfer)**: The financial impact is shared with a third party, typically through insurance or outsourcing. **Crucial distinction**: You can transfer the financial cost (First-party liabilities) and sometimes legal costs (Third-party liabilities), but **you can never transfer the Reputation Risk** or the accountability regarding laws like GDPR.

Residual Risk

The concept of Residual Risk is central to the treatment phase.

$$\text{Residual Risk} = \text{Inherent Risk} - \text{Mitigation Impact}$$

Treatment is a cyclical process. Once a treatment plan is formulated and controls are applied, we must calculate the new residual risk. If it is still above the organization's risk appetite, we must loop back and apply further treatments. If it is below the threshold, the management signs off on the **Risk Acceptance**.

14.3 Security Controls and Defense in Depth

Types of Controls

To mitigate risk, we apply "Controls." These can be categorized in two ways.

By **Implementation Nature**:

- **Physical Controls**: Fences, guards, locks, fire suppression systems.
- **Technical (Logical) Controls**: Firewalls, encryption, antivirus, IDS/IPS.
- **Organizational (Administrative) Controls**: Policies, training, background checks, legal contracts.

By **Function (Timing)**:

- **Preventive**: Stops the attack before it happens (e.g., Firewall blocking a port).
- **Detective**: Identifies that an attack is happening (e.g., IDS alert, Log monitoring).
- **Corrective**: Restores the system after the attack (e.g., Backups, Patching).

Defense in Depth (The Onion Model)

The professor emphasizes that no single control is perfect. Therefore, we adopt a **Defense in Depth** strategy, often visualized as layers of an onion. If an attacker breaches the physical perimeter, they face the network firewall. If they bypass the firewall, they face the endpoint antivirus. If they compromise the endpoint, they face application access controls (MFA). If they get the data, it should be encrypted. Multiple overlapping layers ensure that the failure of one control does not lead to a total breach.

14.4 Focus on Cloud Risks and Misconfiguration

The Shared Responsibility Model

When moving to the Cloud (IaaS, PaaS, SaaS), the organization treats risk by transferring *some* management duties to the provider (like Amazon AWS or Microsoft Azure). However, security remains a shared responsibility. The provider protects the "Cloud" (infrastructure, hardware), but the customer must protect what is "IN the Cloud" (data, access configuration).

The Threat of Misconfiguration

The professor highlights that the most significant risk in cloud environments is not the provider being hacked, but the customer making a **Cloud Misconfiguration**. Common examples include:

- **Unrestricted Access:** Leaving storage buckets (e.g., AWS S3) open to the public internet.
- **Overly Permissive Keys:** Granting administrative privileges to users or apps that don't need them.
- **Hardcoded Secrets:** Developers leaving API keys or passwords inside the source code (e.g., on GitHub).
- **Disabled Logging:** Turning off monitoring to save money/effort, which makes forensic investigation impossible after a breach.

14.5 The Engineering Compromise

The Triangle of Constraints

The final lesson of this chapter is about the reality of the CISO's job. We do not operate in a vacuum. We are constrained by **Money, Time, Law, and Competences**. We face a constant trade-off between: 1. **Security** 2. **Usability (for business)** 3. **Cost** You cannot maximize all three. High security often reduces usability or increases cost.

The Goal of Engineering

Quoting Randy Pausch: *"Engineering is not about perfect solutions. It's about doing the best you can with limited resources."* The challenge is finding

the best **Compromise**. We cannot eliminate all risks (that would be infinitely expensive and would freeze the business). We must optimize our defenses to protect the most critical assets (the "3+1" rule) against the most likely threats, within the available budget.

14.6 Recap

Evaluation vs. Analysis: Analysis gives you the numbers (High/Low); Evaluation compares those numbers to the "Risk Appetite" to decide if they are acceptable.

Treatment Loop: If risk $\geq$ appetite, you Treat it. Calculate Residual Risk. If still $\geq$ appetite, Treat again. If $<$ appetite, Accept.

Defense in Depth: Never rely on one lock. Use Physical + Technical + Organizational layers (Preventive, Detective, Corrective).

Cloud Reality: The Cloud is secure, but *your configuration* of it might not be. Misconfiguration (e.g., open S3 buckets) is a top threat.

The Engineering Mindset: Perfection is impossible. The goal is the best possible security compromise given the limited budget and the need for business usability.

15 Case Study: Personal Device Usage Policy (ACME S.p.A.)

15.1 Purpose, Scope, and Rationale

The Goal of the Policy

This document serves as a practical example of a "Security Policy" designed for a critical infrastructure provider (ACME S.p.A.). The primary objective is not merely to restrict users but to protect the company's network perimeter and sensitive infrastructure data. The policy explicitly applies to all personnel, including employees, contractors, and consultants, ensuring that no one is exempt from security obligations.

The Rationale: Why prohibit personal devices?

The policy adopts a strict approach, strongly discouraging the use of personal devices for work activities. This decision is based on a specific risk assessment. The document identifies four key risks introduced by personal devices: First, **Malware Introduction:** Personal devices lack corporate controls and may introduce malicious software into the secure network. Second, **Data Leakage:** Uncontrolled devices could easily export sensitive data without the company knowing. Third, **Compatibility and Support:** The IT department cannot guarantee support for a myriad of consumer devices, leading to operational inefficiencies. Fourth, **Lack of Visibility:** The company cannot monitor the security posture of a personal phone (e.g., is it patched?), creating a blind spot in the defense.

15.2 Operational Guidelines: Do's and Don'ts

Prohibited Activities

The policy establishes clear "Red Lines" that must never be crossed. Users are strictly prohibited from connecting personal devices to the **Corporate Network** (wired or wireless). This is a critical perimeter defense measure. Furthermore, storing **Sensitive Information** (such as customer data, financial records, or infrastructure data) on personal devices is forbidden. Bypassing security controls (e.g., "jailbreaking" or "rooting" a phone) is explicitly banned, as it undermines the device's built-in security. Finally, using personal devices to create "shadow networks" (like wireless hotspots) that bridge to the corporate network is prohibited to prevent unauthorized entry points.

Permitted Use

The policy acknowledges that some personal device usage is inevitable but restricts it to safe zones. Connection is allowed only to the **"Guest" Wi-Fi network**, which is logically separated from the corporate intranet. Crucially, personal devices are permitted for **Multi-Factor Authentication (MFA)** applications. This is a vital distinction: the phone is used as an authentication token, not as a workspace. Voice calls and limited incidental use are allowed, provided they do not interfere with duties.

15.3 Security Requirements and Governance

User Responsibilities

Even for limited use, the device must meet minimum security standards. The user must ensure the device has an active antivirus (where applicable), is kept updated with the latest OS patches, and is secured by a PIN or biometric lock. The policy introduces a "duty to report": if a device containing any corporate data (even if just an email) is lost or stolen, the user must report it to the IT Security Department immediately to allow for damage containment.

Privacy and Data Protection

A critical legal and governance aspect is the **Expectation of Privacy**. The policy clearly states that if a user chooses to use a personal device for work purposes (e.g., accessing corporate email), they waive their right to privacy regarding the corporate data on that device. The company reserves the right to monitor corporate data and, in extreme cases (like theft or termination), to remotely wipe the corporate data from the device using Mobile Device Management (MDM) software.

15.4 Recap

Policy Nature: This is a "Governance" document (Administrative Control). It defines the rules of the game before technology is applied.

The Stance: It follows a "Prohibitive" approach. Personal devices are seen as a threat to the perimeter.

Key Restrictions: 1. **No Corporate Network:** Only Guest Wi-Fi. 2. **No Sensitive Data:** Data must stay on company assets. 3. **No Jailbreak:** Security features must remain intact.

The "Why": The rationale is preventing Malware entry (Integrity risk) and Data Leakage (Confidentiality risk).

The Privacy Trade-off: By using a personal device for work, the user accepts that the company can monitor or wipe corporate data on that phone.